

TACTIC APPLICATION SECURITY AUDIT

Toka Approval & Commissioning Technical Inspection Center

Laporan Audit Keamanan Aplikasi Web

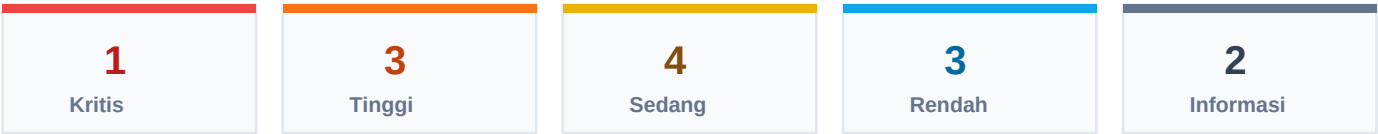
Pemeriksaan Kode Sumber (White-box Source Code Review), Validasi Input, Manajemen Autentikasi, Hak Akses RBAC, dan Analisis Risiko Komprehensif.

APLIKASI TARGET:
TACTIC v2.4 (CI3 / PHP 7.4 / MySQL)

TANGGAL AUDIT:
01 September 2026

LEAD AUDITOR:
Sr. AppSec Engineer

Ringkasan Tingkat Temuan Keamanan:



Daftar Matriks Temuan Audit:

ID	SEVERITY	KATEGORI	DESKRIPSI KERENTANAN
CRIT-01	KRITIS	Data Exposure	Hardcoded Encryption Key pada config.php
HIGH-01	TINGGI	Configuration	Ketiadaan Security Headers HTTP (Clickjacking)
HIGH-02	TINGGI	Session Flaw	Ketiadaan sess_regenerate saat Login Berhasil
HIGH-03	TINGGI	File Upload	Proteksi Eksekusi Skrip Direktori uploads/.htaccess
MED-01	SEDANG	Password	Kebijakan Kompleksitas Password Belum Ditegakkan
MED-02	SEDANG	Data Exposure	Kredensial Database Tersimpan Statis di Source Code
MED-03	SEDANG	Debug Info	Potensi Mode Development Terekspos di Produksi
MED-04	SEDANG	Authorization	Akses URL Langsung Berkas Lampiran Statis
LOW-01	RENDAH	Validation	Pembersihan EXIF Metadata Berkas Gambar
INFO-01	INFO	SQL Injection	Seluruh Query Terparameterisasi (Status: AMAN)
INFO-02	INFO	Audit Trail	Proteksi Brute-Force & Log Komprehensif (Status: AMAN)

Detail Temuan & Rekomendasi Remediasi

CRIT-01: Hardcoded Encryption Key pada Konfigurasi Aplikasi

File: application/config/config.php:331 | Kategori: Sensitive Data Exposure

Kunci enkripsi aplikasi didefinisikan secara statis dengan string bawaan. Jika source code bocor, penyerang dapat mendekripsi data sensitif, ciphertext database, dan token session dengan mudah.

Rekomendasi Remediasi:

Pindahkan encryption_key ke file environment (app_env.php) yang diabaikan dari git repository.

HIGH-01: Ketiadaan Proteksi HTTP Security Headers (Clickjacking)

File: application/config/hooks.php | Kategori: Security Misconfiguration

Aplikasi belum mengirimkan header X-Frame-Options, X-Content-Type-Options, Referrer-Policy, dan Permissions-Policy. Halaman rentan dimuat di dalam iframe situs eksternal untuk meluncurkan serangan Clickjacking.

```
// Tambahkan pada application/hooks/SecurityHeaders.php:  
header('X-Frame-Options: SAMEORIGIN'); header('X-Content-Type-Options: nosniff');
```

Rekomendasi: Aktifkan enable_hooks = TRUE di config.php dan pasang hook SecurityHeaders.

HIGH-02: Kerentanan Session Fixation Saat Login Berhasil

File: application/controllers/Auth.php:173-190 | Kategori: Authentication Flaw

ID sesi tidak diperbarui setelah otentikasi login berhasil. Penyerang dapat menyuntikkan session ID sebelum korban login dan membajak akun setelah login sukses.

Rekomendasi: Panggil \$this->session->sess_regenerate(TRUE); pada saat login valid.

HIGH-03: Penguatan Proteksi Direktori uploads/.htaccess

File: uploads/.htaccess | Kategori: File Upload Security

Aturan .htaccess pada folder uploads masih menggunakan sintaks Apache 2.2 lama dan belum mencakup ekstensi .php8, .pht, .phar. Selain itu, pastikan upload selalu mengaktifkan encrypt_name => TRUE.

Rekomendasi: Perbarui .htaccess ke direktif Apache 2.4 'Require all denied' untuk seluruh ekstensi skrip.

Evaluasi Pertahanan Sistem & Lembar Pengesahan

FITUR KEAMANAN EKSISTING YANG BERJALAN DENGAN BAIK

- 1. Proteksi Brute-Force Login: Database lockout (maks. 5 kegagalan -> lockout 5 menit) aktif.
- 2. Hashing Password Kuat: Menggunakan algoritma BCrypt via password_hash() native PHP.
- 3. Proteksi CSRF Terintegrasi: CSRF protection aktif pada seluruh form POST dan AJAX header.
- 4. Bebas Celah SQL Injection: Seluruh query model menggunakan Active Record dan parameterized escape.
- 5. Jejak Audit (Audit Trail): Seluruh aksi sensitif (login, logout, delete, approval) tercatat di audit_log.
- 6. Akses Read-Only API: Autentikasi token via X-API-KEY dengan perbandingan timing-attack safe (hash_equals).

Prioritas Rencana Aksi Remediasi (Action Plan):

FASE	TINDAKAN PERBAIKAN	LOKASI	TARGET
Fase 1 (Segera)	Pindahkan Encryption Key ke app_env.php	config.php	1 Hari
Fase 1 (Segera)	Pasang Hook Security Headers (Clickjacking)	hooks.php	1 Hari
Fase 1 (Segera)	Tambahkan sess_regenerate saat login	Auth.php	1 Hari
Fase 2 (1 Minggu)	Perbarui uploads/.htaccess ke Apache 2.4	uploads/	3 Hari
Fase 2 (1 Minggu)	Perketat regex validasi password baru	Profil.php	3 Hari
Fase 3 (Rilis)	Set ENVIRONMENT = production & db_debug = FALSE	index.php	Sebelum Go-Live

Disusun Oleh:

Diterima & Disetujui Oleh:

Application Security Team
Senior Security Engineer

Lead Developer / System Admin
TACTIC Technical Operations